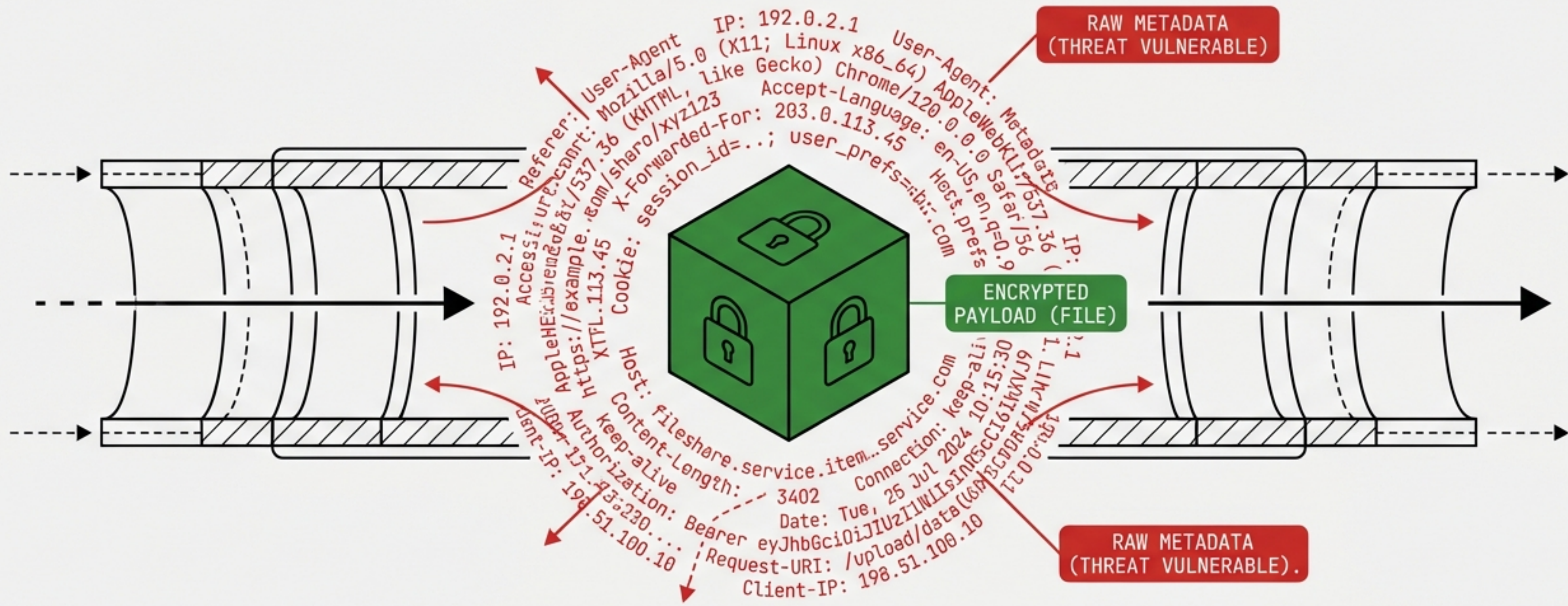
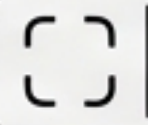


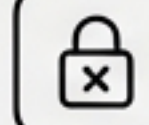
PRIVACY CLASSIFICATION OF HTTP METADATA

A Zero-Knowledge Architecture for File Sharing Services.



 Scope: HTTP Request Metadata

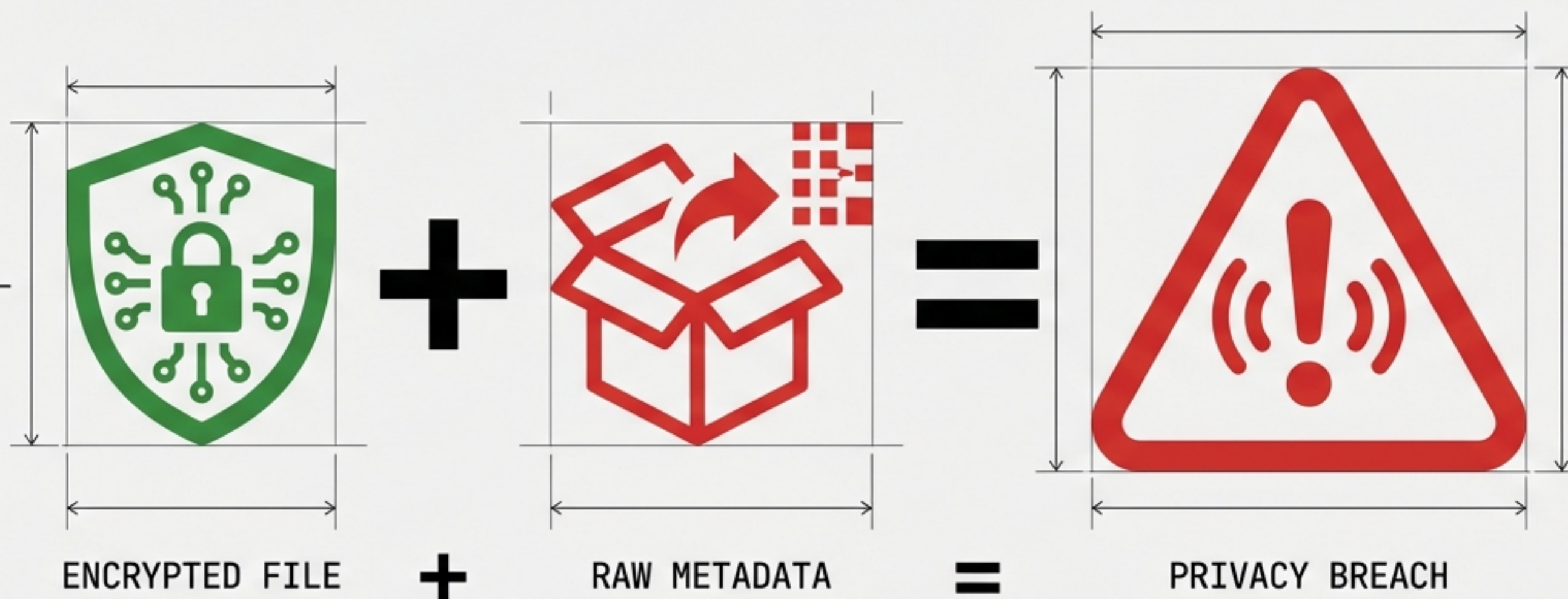
 Compliance: GDPR / CCPA / LGPD

 Status: RESTRICTED

UNIT: 1.0

UNIT: 1.0

THE THREAT MODEL: FULL SERVER COMPROMISE



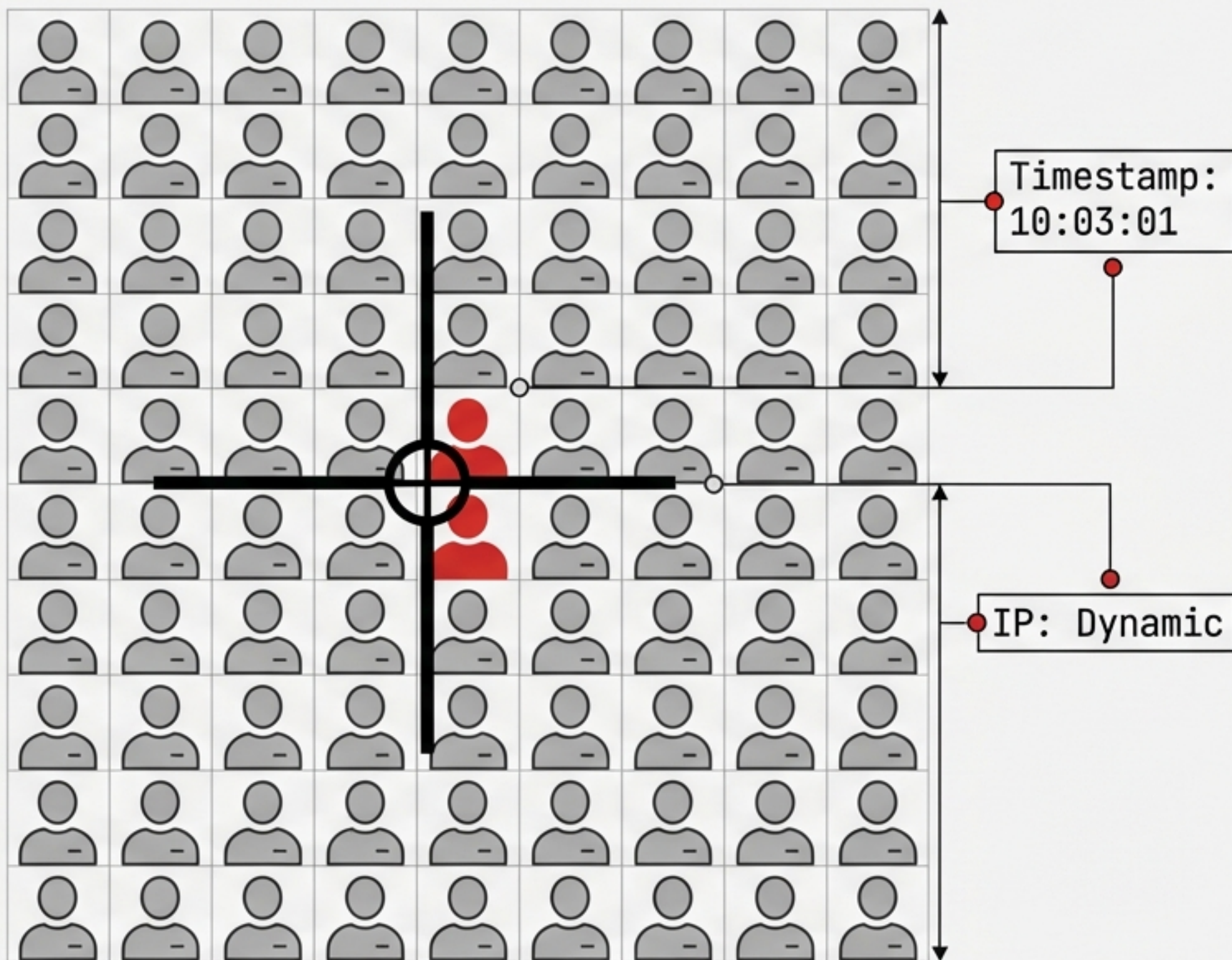
If the database is dumped, metadata must be mathematically useless to the attacker.

THE GAP

- Zero-Knowledge Promise: Host cannot see files.
- The Reality: Metadata allows Singling Out.
- The Result: Linkability creates a user profile.

THE METADATA TRAP: SINGLING OUT

THE PIVOTAL
QUESTION:
Not "Is this a
name?", but
"Can we isolate
this user?"



CITATIONS

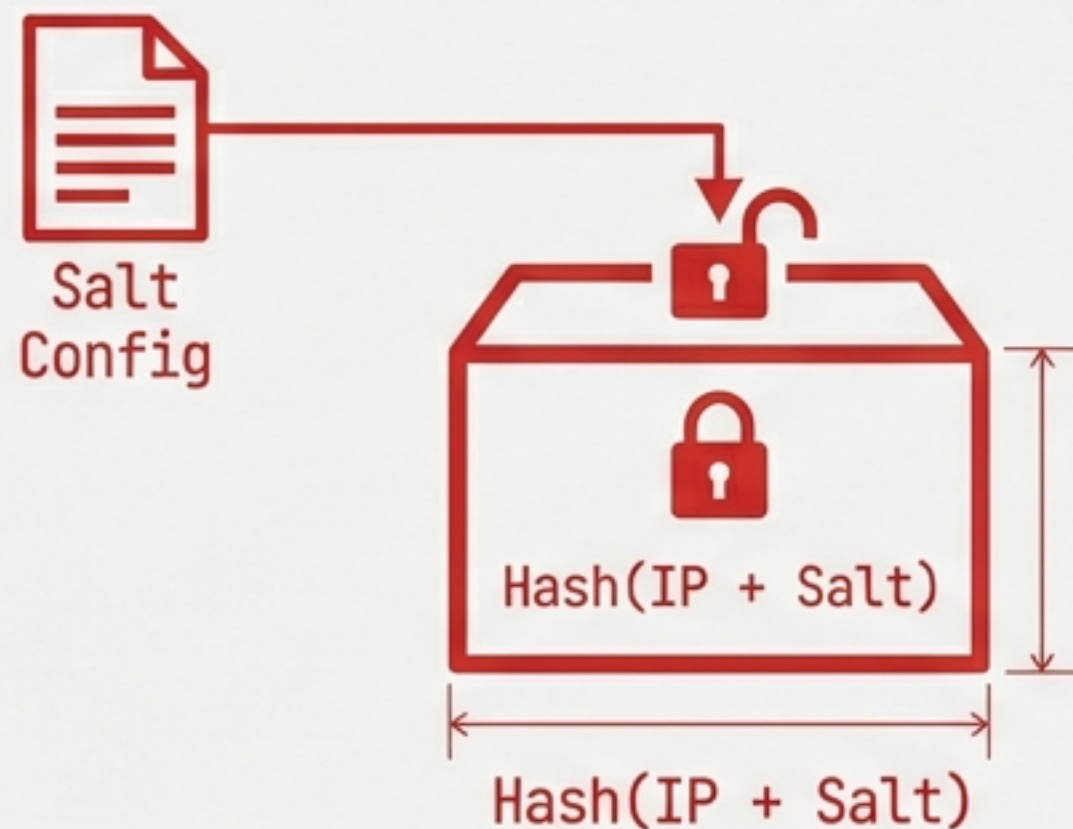
GDPR Recital 26:
Online identifiers
+ timestamps =
Singling Out.

Breyer v. Germany:
Dynamic IPs are
Personal Data
if legal means
exist to
identify.

CCPA: Metadata
capable of being
linked to a
household.

THE MYTH OF 'JUST HASH IT'.

PSEUDONYMISATION



Reversible if salt is compromised.
Allows Linkability ("User X downloaded 50 files").

ANONYMISATION



Aggregated Counters

Irreversible. K-Anonymity.
Safe for Zero-Knowledge.

"If the salt exists anywhere... you have created pseudonymised personal data."

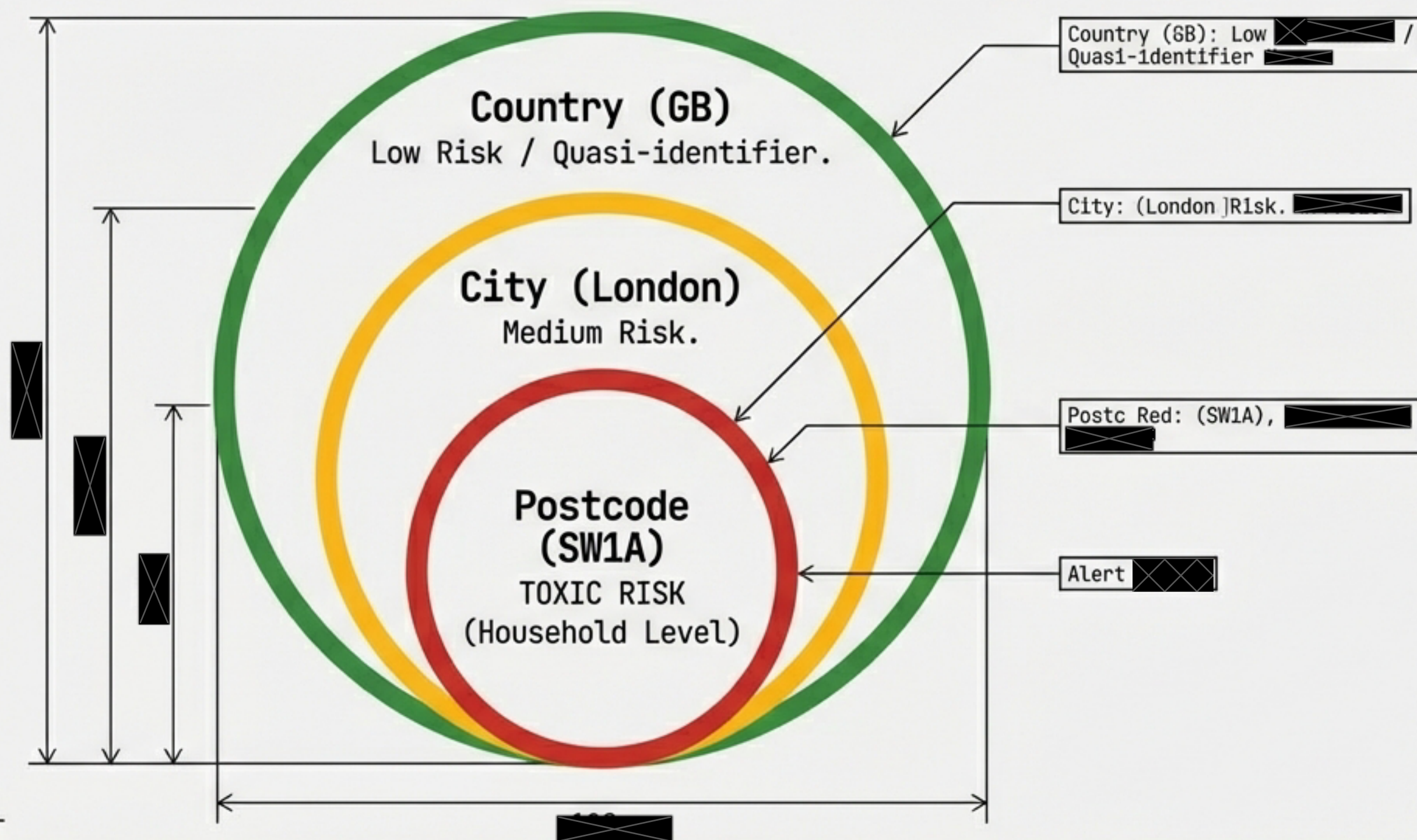
FORENSIC ANALYSIS: THE IP ADDRESS.

STATUS: **PII / HIGH RISK.**

192.168.0.1 **NEVER PERSISTS**  

- The Ultimate Online Identifier.
- Legal Reality (Breyer Case): **Dynamic IPs are personal data** because **ISP logs exist.**
- Design Rule: **Use ephemerally for rate-limiting** (in-memory), then **discard immediately.**

FORENSIC ANALYSIS: GEOLOCATION & GRANULARITY.

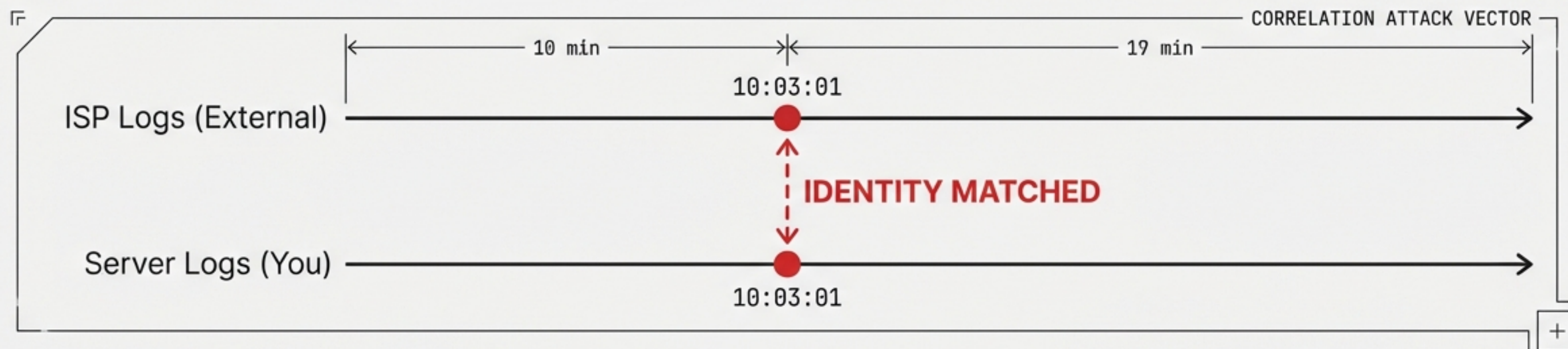


Data Point: A UK
postcode averages
~15 addresses.
Storing this
enables targeting.

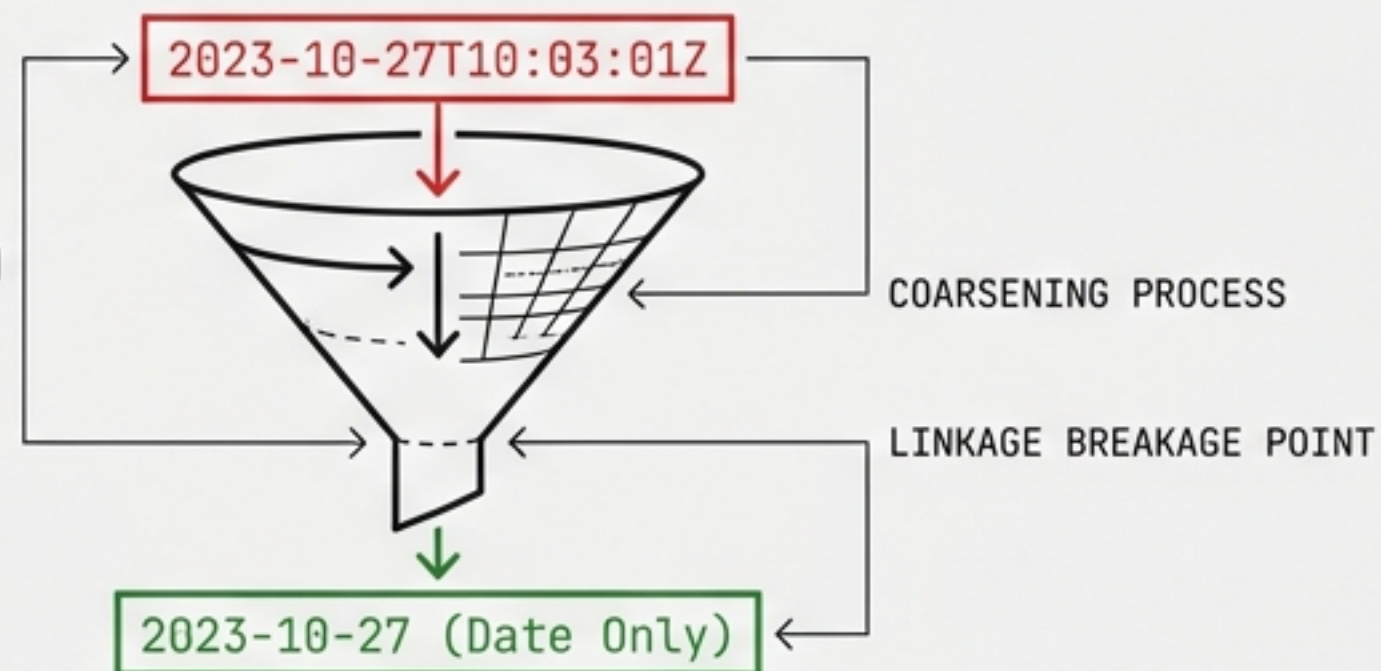
ACTION:
Store ISO Country
Code only. Discard
everything else.

FORENSIC ANALYSIS: TIMESTAMPS

The Vector: Correlation Attacks



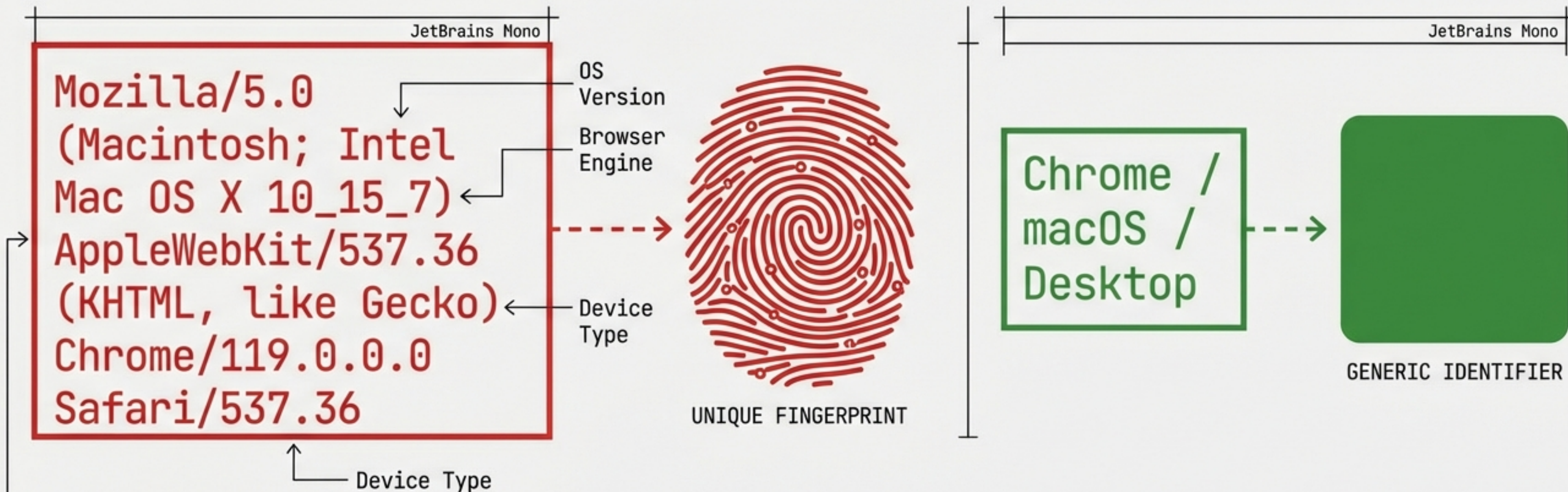
Solution



Coarsen the data to break the link.

FORENSIC ANALYSIS: USER-AGENTS.

Status: High Entropy Fingerprint.

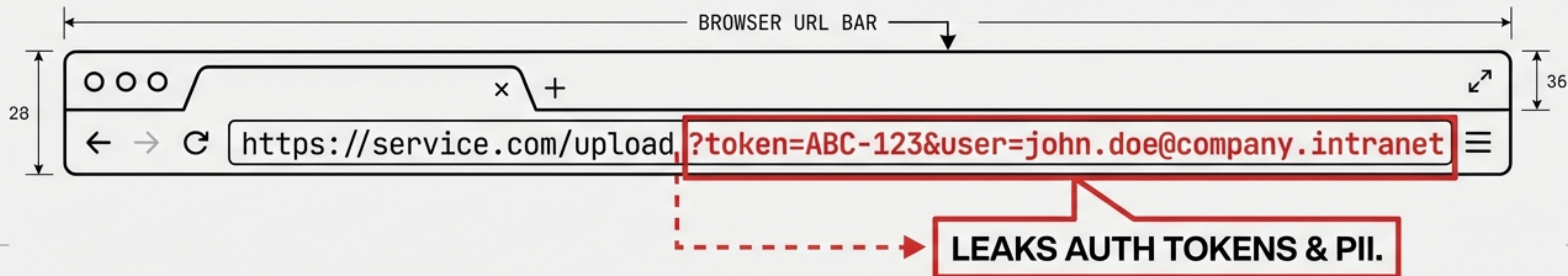


EFF Research Data Point: UA strings carry ~10.5 bits of identifying info. Unique to 1 in 1500.

ACTION: Normalize and Discard the raw string.

FORENSIC ANALYSIS: REFERRERS & QUERY PARAMS.

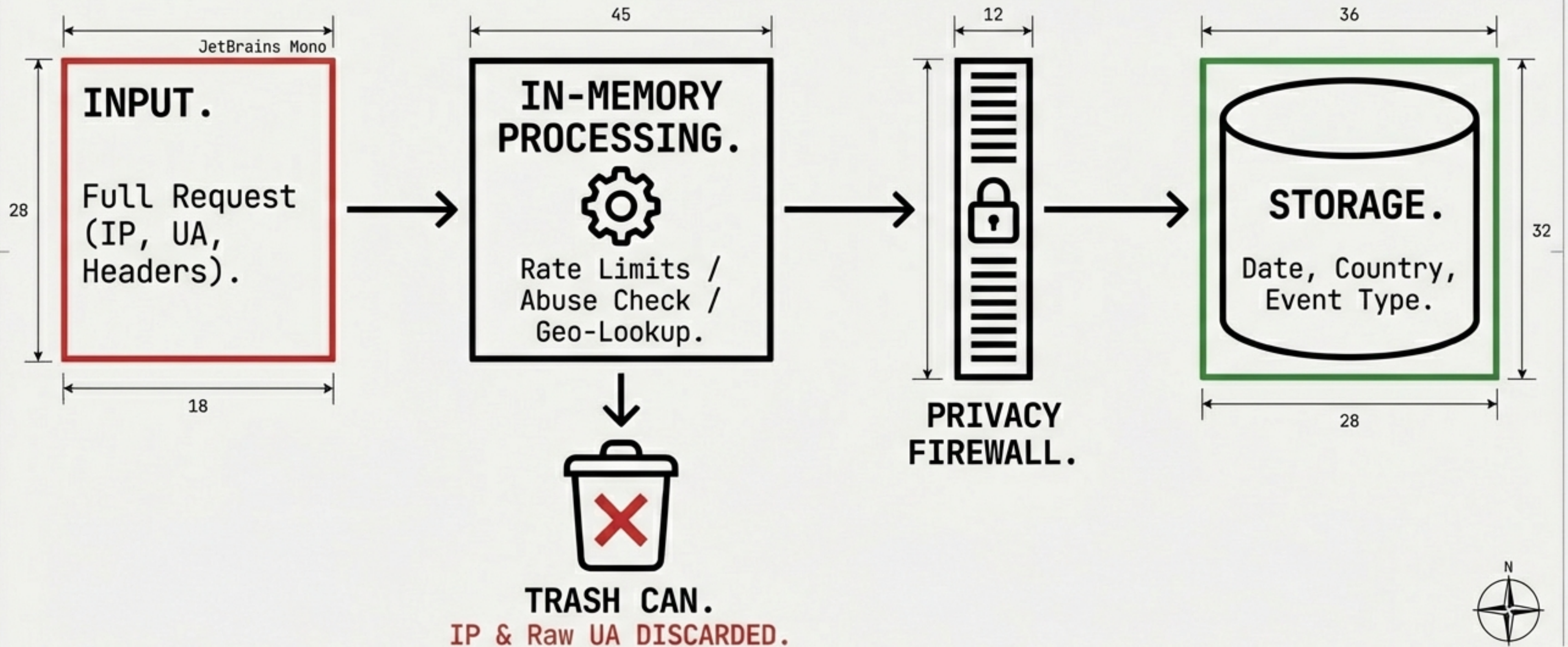
Status: Toxic / Uncontrollable.



15	Design Rule: Absolute prohibition on storage.	
27	Reasoning: These fields are structurally uncontrollable. Upstream sites leak private data in Referrers. Users leak tokens in URLs.	
22	ACTION: Normalize and Discard the raw string.	20

THE ARCHITECTURE OF PRIVACY.

Derive Live, Do Not Persist.



TIER 1: THE 'SAFE TO STORE' LIST

Minimal Viable Dataset (Green List)

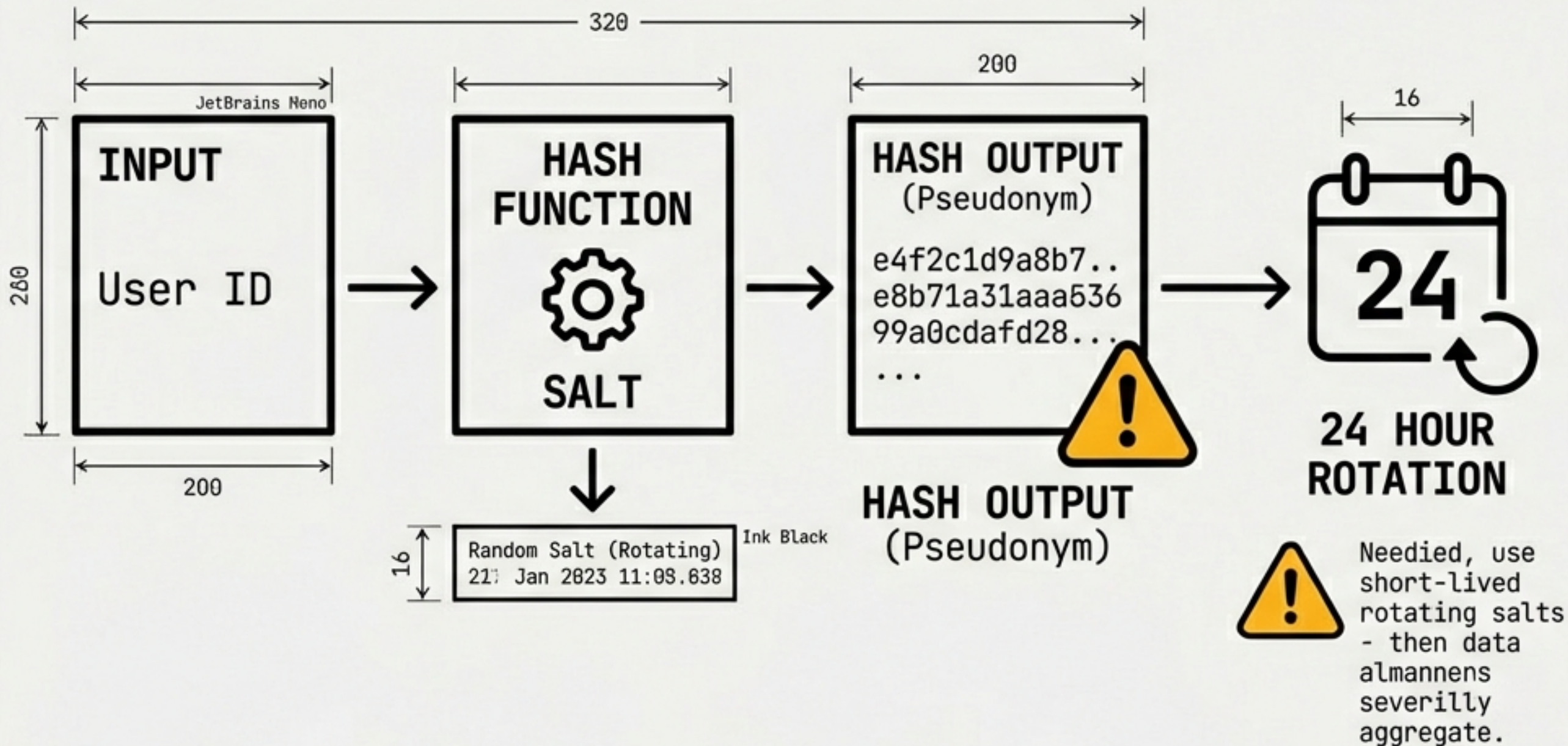
✓	Event Type: Upload / Download
✓	Coarsened Timestamp: Date Only (YYYY-MM-DD)
✓	Country Code: ISO Format (e.g., GB)
✓	Device Class: Mobile / Desktop
✓	Bandwidth Buckets: 1-10MB (No exact byte counts)

OPERATIONAL NECESSITY:

Supports analytics without enabling singling out.

TIER 2: THE 'DANGER ZONE' (HASHING).

The Zero-Knowledge Rule: Avoid stable pseudonyms.

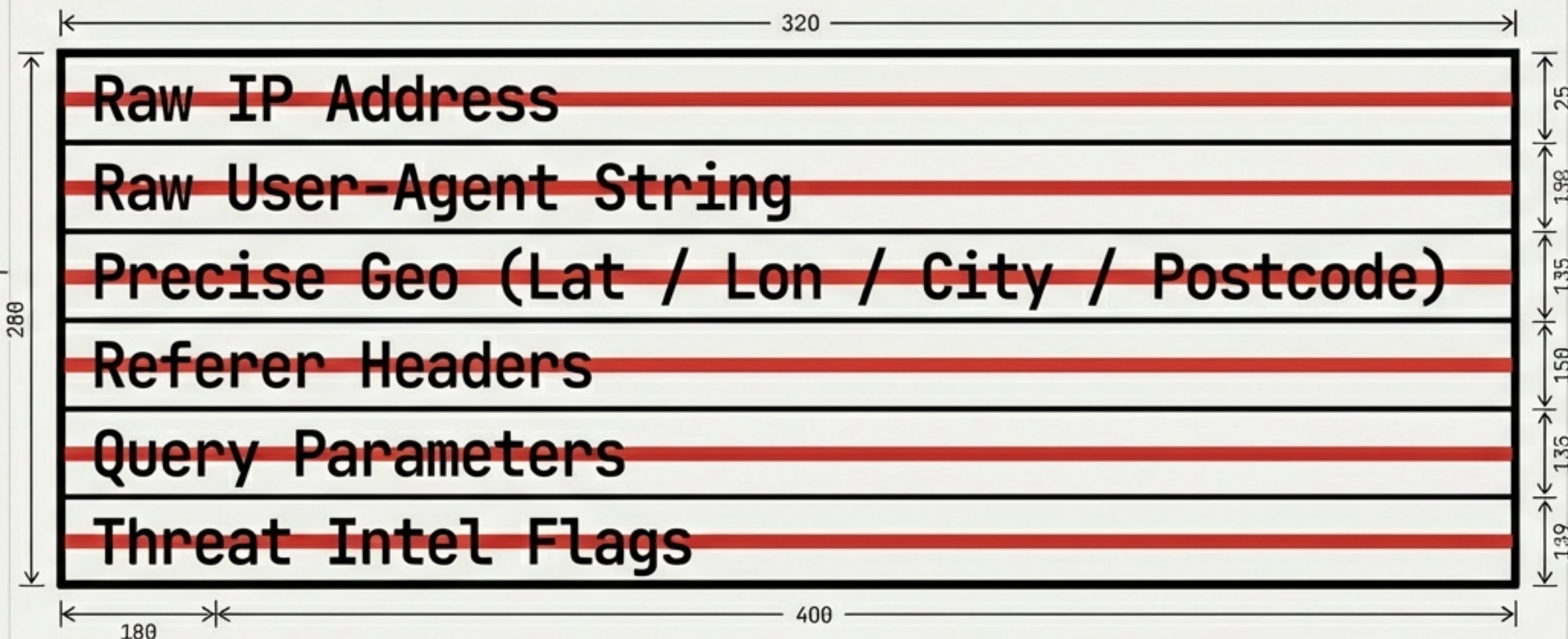


Risk: Storing **Hash(IP)** reveals behavioral patterns over time ("User X downloaded 50 files").

Recommendation: If needed, use **short-lived rotating salts**, then **aggregate**.

TIER 3: THE 'DISCARD' LIST.

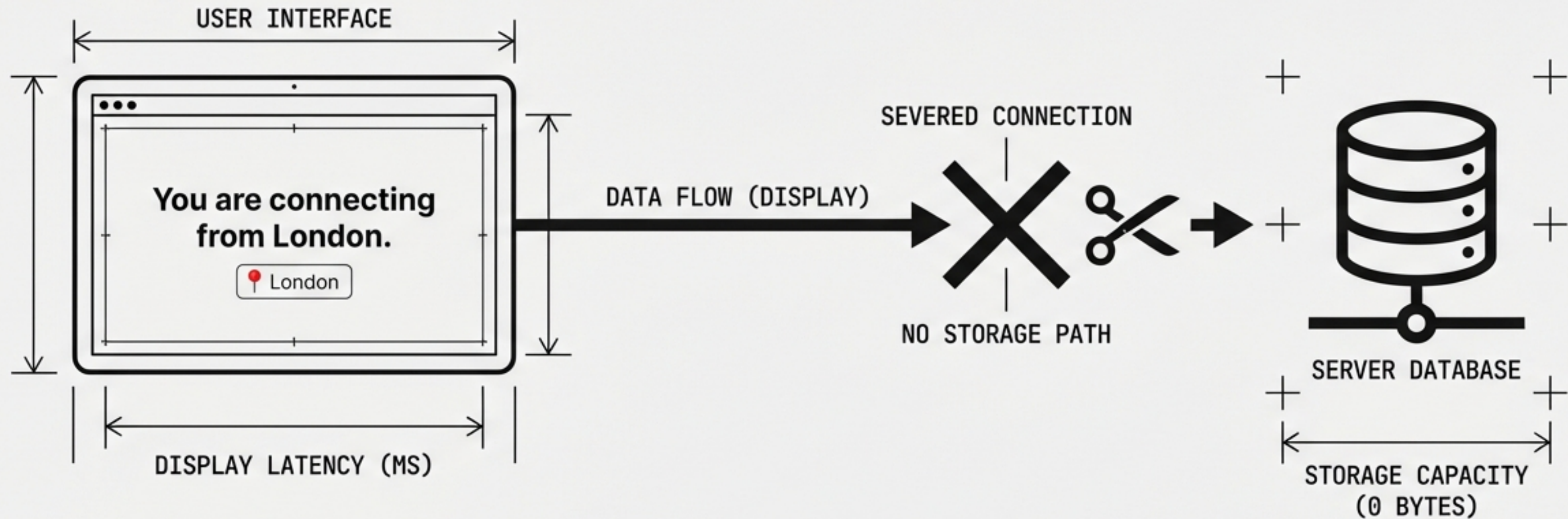
Toxic Data (Red List).



Legal Basis: These constitute 'Means Reasonably Likely' to identify (GDPR Recital 26).

THE TRANSPARENCY PARADOX.

Can we show the user their metadata without storing it?



MECHANISM: SHOW-THEN-DISCARD.

1. Displaying = Processing (Requires Notice). ✓
2. Not Storing = Data Minimisation (Compliance). ✓

You do not need to store personal data just to prove you showed it.

IMPLEMENTATION SUMMARY

FIELD	SHOW TO USER	STORE ON SERVER	FORMAT
IP Address	Yes	Never store	Discard (Used ephemerally for abuse/rate limiting only)
User-Agent	Yes	Yes (minimised)	Normaliised: {browser_family, os_family} + device_class; no raw UA string
Accept-Language	Yes	Yes (minimised)	Primary language tag only (e.g., "en")
Timestamp	Yes	Yes (coarsened)	UTC date or hour-bucket (no exact seconds)
Country	Yes	Yes	ISO country code (e.g., "GB")
Region/State	Yes (optional)	Prefer not	If needed: coarse region + k-thresholding
City	Yes (optional)	Never store	Discard
Postcode	Optional	Never store	Discard
Latitude/Longitude	Yes (optional)	Never store	Discard
ISP/Organisation	Yes (optional)	Prefer not	Discard (or store only coarse "hosting/residential")
ASN	Yes (optional)	Prefer not	Discard (or store only coarse risk category)
Connection type	Yes (optional)	Prefer not	Discard (or store coarse bucket only)
VPN/Proxy/Tor flag	Yes (optional)	Prefer not	Discard (store only ephemeral decision)
Device type (mobile/desktop)	Yes	Yes	device_class enum
TLS version	Yes	Yes	tls_version_major_minor (e.g., "1.3")

Minimisation is Security. By discarding identifiers, we render the 'S3 Dump' harmless.